

WYDZIAŁ INFORMATYKI I TELEKOMUNIKACJI
Instytut Informatyki

Praca dyplomowa magisterska

**ANALIZA RUCHU SIECIOWEGO APLIKACJI MOBILNYCH NA
PLATFORMIE ANDROID**

Mikołaj Kmiecik, nr albumu 147575

Promotor
dr inż. dr inż. Michał Kalewski

POZNAŃ 2025

Streszczenie

Przedmiotem pracy jest analiza ruchu sieciowego generowanego przez wybrane aplikacje mobilne systemu Android. Zaimplementowano środowisko przechwytywania (mitmproxy, tcpdump), normalizacji i klasyfikacji z uwzględnieniem protokołów (HTTP/1.1, HTTP/2, QUIC), szyfrowania TLS oraz aspektów prywatności (domeny trackingowe, identyfikatory). Wyniki obejmują statystyki protokołów, charakterystykę ruchu według kategorii aplikacji oraz ocenę ryzyk potencjalnego ujawniania metadanych.

Słowa kluczowe: Android, analiza ruchu, TLS, QUIC, prywatność, mitmproxy.

Abstract

This thesis investigates network traffic generated by selected Android applications. A modular environment for traffic interception (mitmproxy, tcpdump), normalization and classification was implemented, focusing on protocols (HTTP/1.1, HTTP/2, QUIC), TLS encryption and privacy aspects (tracking domains, identifiers). Results include protocol usage statistics, traffic characteristics across app categories, and an assessment of potential metadata exposure risks.

Keywords: Android, network traffic analysis, TLS, QUIC, privacy, mitmproxy.

Spis treści

1	Wstęp	5
1.1	Motywacja	5
1.2	Stan wiedzy	7
1.2.1	Analiza ruchu sieciowego	7
1.2.2	Inżynieria wsteczna i testy penetracyjne	7
1.2.3	Prywatność, uprawnienia i trackery	7
1.2.4	Zużycie zasobów i kontekst behawioralny	7
1.2.5	Podsumowanie	7
1.3	Cel i zakres pracy	8
2	Przegląd literatury i technologii	9
2.1	Architektura systemu Android	9
2.2	Model bezpieczeństwa	9
2.3	Protokoły	9
2.4	Techniki analizy ruchu	9
2.5	Prywatność i tracking	9
2.6	Powiązane badania	9
3	Metodyka badawcza	11
3.1	Kryteria doboru aplikacji	11
3.2	Środowisko testowe	11
3.3	Procedura przechwytywania	11
3.4	Automatyzacja interakcji	11
3.5	Model danych i metryki	11
3.6	Anonimizacja i etyka	11
3.7	Walidacja	11
4	Architektura rozwiązania	13
4.1	Przegląd komponentów	13
4.2	Diagram wysokopoziomowy	13
4.3	Przepływ danych (ETL)	13
4.4	Struktura repozytorium	13
4.5	Model normalizacji	13
4.6	Rozszerzalność	13
5	Implementacja	15
5.1	Moduł przechwytywania	15
5.2	Hooki mitmproxy	15

5.3	Parser i normalizacja	15
5.4	Klasyfikacja domen	15
5.5	Agregacje i raporty	15
5.6	Testy	15
6	Eksperymenty i wyniki	17
6.1	Plan eksperymentalny	17
6.2	Charakterystyka próbek	17
6.3	Wykorzystanie protokołów	17
6.4	Analiza domen trackingowych	17
6.5	Czasy odpowiedzi i rozmiary	17
6.6	Ograniczenia	17
7	Aspekty bezpieczeństwa i prywatności	19
7.1	Szyfrowanie i wersje TLS	19
7.2	Certificate pinning	19
7.3	Potencjalne wycieki metadanych	19
7.4	Domeny trackingowe	19
7.5	Implikacje	19
8	Dyskusja	21
8.1	Interpretacja wyników	21
8.2	Porównanie z literaturą	21
8.3	Zagrożenia dla ważności	21
8.4	Perspektywa praktyczna	21
9	Wnioski i dalsze prace	23
9.1	Podsumowanie	23
9.2	Odpowiedzi na pytania badawcze	23
9.3	Możliwe rozszerzenia	23
	Bibliografia	25

Rozdział 1

Wstęp

1.1 Motywacja

Rynek aplikacji mobilnych stał się dominującym kanałem konsumpcji treści i usług cyfrowych. Według danych branżowych dotyczących penetracji dostępu mobilnego (71% globalnej populacji z subskrypcją mobilną do 2023 r.) [2] oraz aktualnych statystyk udziału ruchu WWW (ponad 50% globalnych page views pochodzi z urządzeń mobilnych) [5] środowisko mobilne stanowi kluczowy obszar analizy zachowań komunikacyjnych i ryzyk prywatności. W ekosystemie Androida współistnieją tysiące bibliotek firm trzecich (analityka, reklama, personalizacja, antyfraud), które wprowadzają dodatkowe warstwy komunikacji sieciowej – często poza świadomością użytkownika i częściowo także poza kontrolą dewelopera końcowej aplikacji. Ta rosnąca heterogeniczność przekłada się na trudności w:

- a) uzyskaniu przejrzystości jakie protokoły i domeny są wykorzystywane,
- b) ocenie ryzyka ekspozycji metadanych (host, czas, wielkości transferów) mimo powszechnego szyfrowania treści,
- c) porównywalności zachowań komunikacyjnych między kategoriami aplikacji (komunikatory, multimedia, finanse, gry),
- d) tworzeniu powtarzalnych narzędzi badawczych radzących sobie z ewolucją protokołów (HTTP/2, HTTP/3/QUIC) i mechanizmami obronnymi (certificate pinning).

Drugi wektor motywacyjny stanowi szybka adopcja nowych protokołów transportowych i warstw aplikacyjnych. QUIC (standaryzowany jako HTTP/3 [6]) przenosi część logiki transportu do przestrzeni użytkownika (UDP + TLS 1.3 [13]), co zmienia charakterystykę obserwowalnych cech przepływów: klasyczne estymatory opóźnień i retransmisji z poziomu TCP stają się mniej bezpośrednie, a analiza pakietów jest utrudniona przez szyfrowanie większej liczby pól. W konsekwencji wcześniejsze proporcje protokołów publikowane w literaturze mogą być nieaktualne dla obecnych wersji popularnych aplikacji.

Kolejnym aspektem jest prywatność i otoczenie regulacyjne. RODO (GDPR), a także DMA-/DSA w UE akcentują minimalizację i przejrzystość przetwarzania. Architektura „multi-endpoint” (API własne + analityka + reklamy + antyfraud + CDN/edge) prowadzi do gęstych, równoległych zestawów połączeń tuż po interakcji użytkownika. Nawet przy pełnym szyfrowaniu treści korelacja metadanych (częstotliwość, rozmiary odpowiedzi, domeny) może ujawniać wzorce użycia funkcji (pattern-of-life). Transparentność takich wzorców jest ograniczona zarówno dla użytkownika, jak i

audytorów. Narzędzia systemowe dają uogólniony obraz, a techniki inwazyjne (hooking, dynamic instrumentation) bywają blokowane przez mechanizmy anty-tampering.

Istnieje także motywacja praktyczna stworzenia lekkiego, powtarzalnego środowiska badawczego balansującego między:

- **Zasięgiem obserwacji** (kompletność metadanych HTTP[S]),
- **Inwazyjnością** (brak konieczności rootowania, minimalne modyfikacje),
- **Zgodnością prawną i etyczną** (anonimizacja identyfikatorów, brak utrwalania treści wrażliwych).

Istniejące narzędzia (np. *mitmproxy*) zapewniają bazowy przechwyt, ale wymagają rozszerzeń o:

- **Normalizacja** – ujednolicenie formatu danych.
- **Klasyfikacja** – kategoryzacja ruchu sieciowego.
- **Agregacja** – zbieranie i analiza metryk.
- **Automatyzacja** – skrypty do interakcji z aplikacjami.
- **Anonimizacja** – ochrona danych osobowych.

Z naukowego punktu widzenia identyfikowane luki obejmują:

- L1** Brak bieżących, empirycznych pomiarów dystrybucji HTTP/1.1 vs HTTP/2 vs QUIC w popularnych aplikacjach.
- L2** Ograniczone porównania między kategoriami aplikacji a zachowaniami komunikacyjnymi.
- L3** Niedostatek jawnych metryk ryzyka prywatności bazujących wyłącznie na metadanych.
- L4** Fragmentaryczne dane o wpływie certificate pinning na pokrycie przechwytu.

Interesariusze:

- **Użytkownik** – zyskuje pośrednio poprzez privacy-by-design.
- **Deweloper** – możliwość audytu nadmiarowych zależności.
- **Audytor bezpieczeństwa** – metryki priorytetyzacji ryzyka.
- **Społeczność naukowa** – powtarzalny pipeline do dalszych badań.

Kluczowe osie motywacji:

1. **Ewolucja protokołów i szyfrowania**
2. **Prywatność i regulacje**
3. **Złożoność komponentów trzecich**
4. **Replikowalność i standaryzacja**

1.2 Stan wiedzy

1.2.1 Analiza ruchu sieciowego

Badania pokazują, że ruch generowany przez aplikacje mobilne niesie znaczące wyzwania dla prywatności – nawet konfiguracje TLS nie chronią całkowicie, bo analizę można przeprowadzać na metadanych lub kanałach bocznych. W przeglądzie literatury poświęconym analizie ruchu mobilnego autorzy klasyfikują cele, miejsca przechwytywania oraz metody wykorzystania danych sieciowych do profilowania użytkowników [12]. Inne prace demonstrują, jak sieć może zostać wykorzystana do identyfikacji konkretnej aplikacji, nawet przy szyfrowaniu, wykorzystując uczenie maszynowe na podstawie cech pakietów **Taylor2016AppFingerprinting**. Przykłady wykorzystania narzędzi takich jak *mitmproxy* i *tcpdump* pokazują, jak można wychwycić i analizować zarówno HTTP jak i inne kanały sieciowe [7], [11].

1.2.2 Inżynieria wsteczna i testy penetracyjne

Inżynieria wsteczna aplikacji mobilnych, ułatwiająca badanie mechanizmów takich jak SSL pinning, jest szeroko stosowana. Badania przedstawiają różne metody obchodzenia tej ochrony **Husain2024SSLPinningBypass**. Wczesne prace wskazują na powszechne błędy konfiguracji SSL w aplikacjach Androidowych — ponad połowa analizowanych aplikacji korzystających z SSL miała błędne wdrożenia lub brak obsługi poprawnego pinningu [15]. W celu przeprowadzania dynamicznych testów bezpieczeństwa wykorzystuje się narzędzia takie jak *Frida*, *Drozer* czy *MobSF*, które wspierają zarówno analizę dynamiczną, jak i automatyzację [4], [8].

1.2.3 Prywatność, uprawnienia i trackery

Coraz więcej badań zwraca uwagę na skalę gromadzenia danych przez aplikacje mobilne. Jedno z systematycznych opracowań analizujących prywatność w aplikacjach Android zwraca uwagę na różnorodność technik (statycznych, dynamicznych i hybrydowych) oraz wskazuje na luki w zgodności z regulacjami prawnymi **Alazam2021PrivacySurvey**. Narzędzia takie jak *Exodus Privacy* umożliwiają analizę APK pod kątem wbudowanych trackerów i uprawnień [3]. Wyniki badań praktycznych pokazują, że aplikacje często żądają nadmiarowych uprawnień lub integrują zewnętrzne trackery reklamowe [1].

1.2.4 Zużycie zasobów i kontekst behawioralny

Nadmierne użycie zasobów (np. bateria, CPU) może wskazywać na obecność komponentów śledzących lub brak optymalizacji. Do pomiarów wykorzystuje się m.in. *Battery Historian* oraz *Android Profiler* [9], [10]. Choć ten aspekt jest rzadziej eksplorowany w literaturze naukowej, podkreśla się jego znaczenie w identyfikacji ukrytych mechanizmów aplikacji [14].

1.2.5 Podsumowanie

Przegląd literatury wykazuje, że istnieje bogata baza wiedzy w obszarach analizy ruchu sieciowego, inżynierii wstecznej, testów penetracyjnych oraz badania prywatności aplikacji mobilnych. Jednocześnie wciąż brakuje holistycznego podejścia, które łączyłoby te wszystkie elementy — co stanowi niszę, którą niniejsza praca ma ambicję wypełnić.

1.3 Cel i zakres pracy

Cel: Celem pracy jest opracowanie i ewaluacja środowiska badawczego umożliwiającego systematyczną analizę bezpieczeństwa i prywatności aplikacji mobilnych na system Android. Praca koncentruje się na przechwytywaniu, klasyfikacji oraz ocenie ruchu sieciowego, a także na badaniu mechanizmów uwierzytelniania, uprawnień i zużycia zasobów.

Zakres pracy obejmuje:

- **Środowisko przechwytywania** – konfiguracja narzędzi takich jak *mitmproxy*, *Wireshark*, *tcpdump*, a także przygotowanie środowiska laboratoryjnego z wykorzystaniem emulatorów oraz zrootowanych urządzeń mobilnych.
- **Analiza ruchu sieciowego** – identyfikacja używanych protokołów (HTTP/1.1, HTTP/2, QUIC, TLS), badanie bezpieczeństwa transmisji danych (szyfrowanie, SSL pinning) oraz klasyfikacja przesyłanych informacji.
- **Reverse engineering i testy penetracyjne** – dekompilacja aplikacji z wykorzystaniem *APKTool*, *Jadx*, *Ghidra* oraz testy przy użyciu narzędzi takich jak *MobSF*, *Frida*, *Metasploit*.
- **Analiza uprawnień i prywatności** – badanie przydzielanych uprawnień, wykrywanie trackerów i komponentów reklamowych (*Exodus Privacy*, *App Inspector*) oraz ocena zarządzania danymi użytkowników.
- **Analiza zużycia zasobów** – pomiary obciążenia baterii i CPU aplikacji z użyciem *Battery Historian* oraz *Android Profiler*.
- **Eksperymenty** – testy na wybranych aplikacjach z różnych kategorii (m.in. komunikatory, aplikacje społecznościowe, bankowe, rządowe), analiza różnic w implementacji mechanizmów bezpieczeństwa.
- **Badanie wektorów ataków** – symulacja ataków typu *Man-in-the-Middle*, analiza przechwytywania danych lokalnych, scenariusze działania offline/online, testy odporności na automatyczne skrypty i boty.
- **Analiza logów i ścieżki audytu** – sprawdzenie, jakie dane aplikacje rejestrują w logach oraz ocena ryzyka wycieku informacji.

Rozdział 2

Przegląd literatury i technologii

2.1 Architektura systemu Android

Krótką charakterystyką warstw (kernel, HAL, ART, framework). Odniesienia do dokumentacji.

2.2 Model bezpieczeństwa

Sandbox, uprawnienia, Store review, mechanizmy ograniczające przechwytywanie (certificate pinning).

2.3 Protokoły

HTTP/1.1, HTTP/2 (multiplexing), HTTP/3/QUIC (UDP, 0-RTT), TLS 1.3 skrócenie handshake [6], [13].

2.4 Techniki analizy ruchu

Narzędzia: tcpdump, Wireshark, mitmproxy, Frida (hookowanie), emulator vs urządzenie fizyczne.

2.5 Prywatność i tracking

Mechanizmy identyfikacji użytkownika, rola domen reklamowych, fingerprinting.

2.6 Powiązane badania

Syntetyczne zestawienie publikacji – wykazać luki (np. niedostateczna analiza QUIC w mobilnych aplikacjach konsumenckich).

Rozdział 3

Metodyka badawcza

3.1 Kryteria doboru aplikacji

Popularność (rankingi store), kategorie (komunikacja, multimedia, finanse), aktualność wersji.

3.2 Środowisko testowe

Sprzęt (model urządzenia), wersja Android, konfiguracja sieci (oddzielony SSID), kontrola tła (tryb samolotowy przed startem sesji).

3.3 Procedura przechwytywania

Instalacja certyfikatu CA dla mitmproxy, konfiguracja proxy systemowego, ograniczenia w wypadku pinningu.

3.4 Automatyzacja interakcji

Skrypty ADB / uiautomator generujące sekwencje działań, logowanie timestampów.

3.5 Model danych i metryki

Pola: timestamp, host, ścieżka, metoda, kod statusu, rozmiary (request/response), protokół (HTTP/2 / QUIC), kategoria domeny, czas odpowiedzi.

3.6 Anonimizacja i etyka

Hashowanie identyfikatorów, odrzucanie payloadów binarnych zawierających potencjalne dane osobowe, brak logowania treści formularzy.

3.7 Walidacja

Losowa weryfikacja spójności liczby pakietów vs liczby zarejestrowanych żądań; test powtarzalności (2 przebiegi).

Rozdział 4

Architektura rozwiązania

4.1 Przegląd komponentów

Opis modułów: przechwytywanie, ekstrakcja, normalizacja, klasyfikacja, agregacja, wizualizacja.

4.2 Diagram wysokopoziomowy

RYSUNEK 4.1: Architektura modułowa środowiska analitycznego (schemat).

4.3 Przepływ danych (ETL)

Kolejne etapy: capture -> parse -> enrich -> store -> stats.

4.4 Struktura repozytorium

Opis katalogów (np. scripts/, data/, analysis/).

4.5 Model normalizacji

Mapowanie surowych atrybutów mitmproxy na ujednolicony rekord JSON/CSV.

4.6 Rozszerzalność

Dodanie nowego klasyfikatora domen lub obsługa innego proxy.

Rozdział 5

Implementacja

5.1 Moduł przechwytywania

Konfiguracja mitmproxy, parametry uruchomienia.

5.2 Hooki mitmproxy

```
1 def response(flow):
2     rec = {
3         "proto": flow.request.scheme,
4         "host": flow.request.host,
5         "path": flow.request.path,
6         "method": flow.request.method,
7         "status": flow.response.status_code,
8         "t_start": flow.request.timestamp_start,
9         "t_end": flow.request.timestamp_end,
10        "length": len(flow.response.raw_content or b"")
11    }
12    save_record(rec)
```

LISTING 1: Hook mitmproxy zapisujący metadane żądań

5.3 Parser i normalizacja

Krok po kroku: walidacja, cast typów, uzupełnianie braków.

5.4 Klasyfikacja domen

Listy znanych trackerów, heurystyki (substring, kategorie TLD, reverse DNS).

5.5 Agregacje i raporty

Obliczanie histogramów, percentyle czasów odpowiedzi.

5.6 Testy

Testy jednostkowe (poprawność mapowania), testy integracyjne (ciąg ETL).

Rozdział 6

Eksperymenty i wyniki

6.1 Plan eksperymentalny

Opis serii sesji, długość, liczba powtórzeń.

6.2 Charakterystyka próbek

Liczba aplikacji, łączna liczba żądań, udział kategorii.

6.3 Wykorzystanie protokołów

Tabela i wykres udziału HTTP/1.1 vs HTTP/2 vs QUIC.

6.4 Analiza domen trackingowych

Odsetek żądań do trackerów per kategoria.

6.5 Czasy odpowiedzi i rozmiary

Rozkłady, mediany, percentyle.

6.6 Ograniczenia

Próbkowanie krótkich okien użycia, brak tła push/pull w długim horyzoncie.

Rozdział 7

Aspekty bezpieczeństwa i prywatności

7.1 Szyfrowanie i wersje TLS

Wykryte wersje, renegotjacje (jeśli obserwowane).

7.2 Certificate pinning

Przypadki utraty widoczności ruchu (fail-open / fail-closed), wpływ na wyniki.

7.3 Potencjalne wycieki metadanych

Parametry w URL, identyfikatory urządzeń, tokeny.

7.4 Domeny trackingowe

Porównanie intensywności ruchu do domen analitycznych.

7.5 Implikacje

Ryzyka dla prywatności użytkownika i rekomendacje (np. ograniczanie uprawnień sieciowych, firewall lokalny).

Rozdział 8

Dyskusja

8.1 Interpretacja wyników

W jakim stopniu dane potwierdzają/obalają hipotezy.

8.2 Porównanie z literaturą

Zestawienie różnic (np. wzrost QUIC vs wcześniejsze badania).

8.3 Zagrożenia dla ważności

Internal: artefakty środowiska testowego; external: różnice regionów geograficznych; konstrukcja: wybór kategorii.

8.4 Perspektywa praktyczna

Wartość dla użytkowników, deweloperów, regulatorów.

Rozdział 9

Wnioski i dalsze prace

9.1 Podsumowanie

Najważniejsze osiągnięcia i wkład.

9.2 Odpowiedzi na pytania badawcze

Zwięzłe odpowiedzi w punktach.

9.3 Możliwe rozszerzenia

Automatyczna detekcja anomalii, uczenie maszynowe do klasyfikacji domen, analiza korelacji z zużyciem energii.

Bibliografia

- [1] A. Razaghpanah, R. Nithyanand, N. Vallina-Rodriguez i in., „Apps, Trackers, Privacy, and Regulators: A Global Study of the Mobile Tracking Ecosystem,” w *Network and Distributed System Security Symposium (NDSS)*, 2018. adr.: https://www.ndss-symposium.org/wp-content/uploads/2018/02/ndss2018_05B-3_Razaghpanah_paper.pdf.
- [2] „Cisco Annual Internet Report (2018–2023) White Paper,” Cisco, 2020, Prognozy do 2023 r.; m.in. penetracja subskrypcji mobilnych (71% global population with mobile subscription by 2023). adr.: <https://www.cisco.com/c/en/us/solutions/collateral/executive-perspectives/annual-internet-report/white-paper-c11-741490.html> (term. wiz. 17.08.2025).
- [3] *Exodus Privacy: Analysis of trackers and permissions in Android apps*, <https://exodus-privacy.eu.org/>, Accessed 2025-08-17, 2025.
- [4] *Frida: A world-class dynamic instrumentation toolkit*, <https://frida.re/docs/home/>, Accessed 2025-08-17, 2025.
- [5] StatCounter, *Global Platform Market Share: Desktop vs Mobile vs Tablet*, Udział globalnych page views według platformy; potwierdza >50% dla urządzeń mobilnych (sprawdź dokładny zakres dat), 2025. adr.: <https://gs.statcounter.com/platform-market-share/desktop-mobile-tablet> (term. wiz. 17.08.2025).
- [6] M. Bishop, *HTTP/3*, RFC 9114, 2022. adr.: <https://www.rfc-editor.org/rfc/rfc9114>.
- [7] *mitmproxy: Interactive TLS-capable intercepting HTTP proxy*, <https://mitmproxy.org/>, Accessed 2025-08-17, 2025.
- [8] *Mobile Security Framework (MobSF) Documentation*, <https://github.com/MobSF/docs>, Accessed 2025-08-17, 2025.
- [9] *Profile battery usage with Batterystats and Battery Historian*, <https://developer.android.com/topic/performance/power/setup-battery-historian>, Accessed 2025-08-17, 2024.
- [10] *Profile your app performance (Android Studio Profiler)*, <https://developer.android.com/studio/profile>, Accessed 2025-08-17, 2024.
- [11] *tcpdump/libpcap*, <https://www.tcpdump.org/>, Accessed 2025-08-17, 2025.
- [12] M. Conti, Q. Li, A. Maragno i R. Spolaor, „The Dark Side(-Channel) of Mobile Devices: A Survey on Network Traffic Analysis,” *arXiv preprint arXiv:1708.03766*, 2017. adr.: <https://arxiv.org/abs/1708.03766>.
- [13] E. Rescorla, *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 8446, 2018. adr.: <https://www.rfc-editor.org/rfc/rfc8446>.
- [14] A. Pathak, Y. C. Hu i M. Zhang, „Where is the Energy Spent in Android Apps? Fine-Grained Energy Accounting on Smartphones with EProf,” w *Proceedings of the 7th ACM European Conference on Computer Systems (EuroSys '12)*, ACM, 2012.

- [15] S. Fahl, M. Harbach, T. Muders, L. Baumgärtner, B. Freisleben i M. Smith, „Why Eve and Mallory Love Android: An Analysis of Android SSL (In)Security,” w *Proceedings of the 2012 ACM Conference on Computer and Communications Security (CCS '12)*, ACM, 2012. adr.: <https://saschafahl.de/static/paper/androidssl2012.pdf>.

(2025)

Instytut Informatyki, Wydział Informatyki i Telekomunikacji
Politechnika Poznańska

Skład przy użyciu systemu L^AT_EX (Overleaf).